LAB 5: STATIC CODE ANALYSIS

Student: Spoorthy M **SRN:** PES1UG24AM280

Date: 11 November 2026

Repository: SETAPESU26/L5_41_library_catalog_system

Python file: library_catalog_system.py

1. Objective

Improve the quality, security, and style of the assigned Python library catalog program using Pylint, Bandit, and Flake8; identify and correct issues; and verify the results using before-and-after analysis reports.

2. Tools and method

Tools: Pylint 4.1.3, Bandit 1.9.4, Flake8 7.5.0; Python 3.11.9. The original script was executed and scanned first. Security issues were corrected, followed by code-quality improvements and formatting corrections. Each stage was recorded in a separate Git commit. The program and analysis tools were run again to verify the final result.

3. Before-and-after results

Tool	Before	After	Outcome
Pylint	5.32/10	10.00/10	Above 9.5 target
Bandit	5 findings (2 high, 1 medium, 2 low)	0 findings	No identified issues
Flake8	6 violations	0 violations	No output (pass)

4. Identified issues and fixes

Issue	Type	Original line(s)	Fix approach
B307 / eval()	Security	42	Replaced unrestricted eval() with restricted AST arithmetic evaluation.
B324 / MD5	Security	47	Replaced MD5 with SHA-256.
B311 / random PIN	Security	51	Used secrets.randbelow() for PIN generation.
B605 / os.system	Security	58	Removed the shell command; used print() for status output.
B110 / bare except/pass	Security	26	Removed silent exception handling; explicitly handled invalid book IDs.
W0102 / mutable default	Correctness	15	Changed list default argument to None and created the list per call.
C0103 / naming	Style	15	Renamed issueBook to issue_book and updated its call.
C0116 / missing docstrings	Maintainability	Several	Added concise function docstrings.
W0612 / unused variables	Maintainability	31, 41	Removed variables that were never used.
W1514 / R1732	Reliability	55	Used with open(..., encoding="utf-8") for safe file handling.
E501 / line length	Style	59 (revised)	Wrapped a long conditional to meet the 79-character limit.
E122 / indentation	Style	60-61 (revised)	Corrected continuation-line indentation.

Line numbers refer to the original file except where explicitly marked as revised. Additional changes included removing a hardcoded librarian token, the unused csv import, and simplifying availability checks.

5. Git commit history

8a70aaf - Fix Bandit security vulnerabilities

a5d6dab - Fix Pylint code quality issues

32bd123 - Fix Flake8 formatting issues

6. Verification

The corrected program executed and reported that book B01 was available and the example fine was 8.0. The final uploaded Pylint report shows 10.00/10, and the final Bandit report states "No issues identified." The final Flake8 report was empty (0 bytes), consistent with zero Flake8 violations. These tool results establish that the configured checks passed; static analysis is not a substitute for comprehensive runtime or security testing.

7. Reflection

What did the tools reveal? Pylint highlighted maintainability and correctness concerns, such as missing documentation, a shared mutable default, and poor resource handling. Bandit found potentially unsafe code execution, weak hashing, predictable PIN generation, shell execution, and exception swallowing. Flake8 identified style problems that made the code less consistent.

Which fixes were most important? Removing unrestricted eval() and shell execution was the highest priority because these patterns can allow unintended operations. Replacing MD5 for a security-oriented hash and using a cryptographically secure PIN generator also improved security.

What did I learn? Static analysis helps identify defects before deployment, and repeated scans make improvements measurable. Small, separately committed changes are easier to review and explain. Passing analysis tools does not guarantee a bug-free program, so functional testing remains important.

8. Submission checklist

Three Git commits; original and corrected Python source versions in Git history; Pylint/Bandit/Flake8 before and after text reports; and this final report. The six report files remain in the local lab folder and should be included with the submission as requested.